ASSIGNMENT-9 : VULNERABILITY SCANNING

GUIDED BY : VIPUL MISTRI

Q.1 Install and run the free version of the OpenVAS or Nessus vulnerability scanner on your system, and perform a basic scan of your own computer or a local virtual machine.

ANS :

Option 1: Nessus Essentials (Industry Standard)

Nessus Essentials is the free version of Tenable Nessus, allowing you to scan up to 16 IP addresses. It is widely used in enterprise security assessments.

1. Installation Steps

1. **Download:** Go to the official Tenable website and register for a **Nessus Essentials** license to receive your activation activation code via email.

2. **Package Selection:** Download the installer matching your OS (e.g., the .deb package for Kali/Ubuntu or the Windows installer).

3. **Install on Linux:**

Bash

sudo dpkg -i Nessus-<version>-debian10_amd64.deb

4. **Start the Nessus Service:**

Bash

sudo systemctl start nessusd

5. **Access the Web Interface:** Open your browser and navigate to https://localhost:8834. Follow the setup wizard, input your activation code, and create an administrator account.

ASSIGNMENT-9 : VULNERABILITY SCANNING

GUIDED BY : VIPUL MISTRI

Option 2: OpenVAS / Greenbone (Open-Source)

If you prefer an entirely open-source vulnerability scanner, **OpenVAS** (part of Greenbone Vulnerability Management) is natively available in security distributions like Kali Linux.

1. Installation & Setup on Kali Linux

1. **Install GVM:**

Bash

sudo apt update

sudo apt install gvm -y

2. **Initialize and Setup:**

Bash

sudo gvm-setup

3. **Start GVM:**

Bash

sudo gvm-start

4. **Access the Interface:** Open your browser and go to https://127.0.0.1:9392.

Running Your First Basic Scan

Once you have your scanner up and running, follow these steps to perform an authorized audit of a lab target (such as a local virtual machine or Metasploitable):

ASSIGNMENT-9 : VULNERABILITY SCANNING

GUIDED BY : VIPUL MISTRI

1. **Create a New Target:**
    - Navigate to **Scans > Targets** (or Scans > New Scan).
    - Enter the IP address of your local test VM (e.g., 192.168.x.x).
2. **Select a Scan Policy:**
    - Choose **Basic Network Scan** (or *Full and Fast*). Avoid aggressive vulnerability exploitation modules unless you are explicitly testing in an isolated lab.
3. **Launch the Scan:**
    - Save the scan configuration and click the **Launch** (play) button.
4. **Analyze the Results:**
    - Once complete, review the vulnerability breakdown categorized by severity (Critical, High, Medium, Low, Info). Click on individual findings to read the description, plugin output, and recommended remediation steps.

Q.2 Scan your Wi-Fi router's IP address using Nmap and list all open ports detected. Hint: Use the command 'nmap -v [router_ip]' in your terminal or command prompt.

ANS : As a cloud-hosted AI assistant, I don't have a physical local network, Wi-Fi router, or network interface card to run an Nmap scan against.

However, you can easily perform this scan on your own local network from your Kali Linux or lab workstation. Here are the step-by-step instructions to find your router's IP address and execute the verbose Nmap scan.

1.Find Your Router's Gateway IP: Network Discovery.

Before scanning, you need your router's IP address (the default gateway). Open your terminal and run:

- **On Linux / Kali:** ip route show | grep default
- **On Windows:** ipconfig (look for "Default Gateway")

Verification: You successfully identify your gateway IP address (commonly 192.168.1.1 or 192.168.0.1).

2.Execute the Verbose Nmap Scan: Nmap Execution.

Run the verbose scan command against your router's IP address, replacing [router_ip] with your actual gateway address:

Bash

sudo nmap -v -T4 [router_ip]

- -v: Enables verbose output so you can see scan progress in real time.
- -T4: Speeds up the timing template for a faster scan.

Verification: Nmap initiates the ping probe and returns the host state as "up".

3.Analyze Discovered Open Ports: Service Inspection.

Review the output to see which ports are listening on your router. Common ports found on consumer and enterprise routers include:

- **Port 53 (DNS):** Local DNS resolver or forwarding service.
- **Port 80 / 443 (HTTP/HTTPS):** Web-based router administration dashboard.
- **Port 22 / 23 (SSH/Telnet):** Command-line management interface (common on advanced or enterprise routers).
- **Port 1900 / 5000 (UPnP / DLNA):** Universal Plug and Play services for media streaming and device discovery.

Q.3 Analyze the scan report from your vulnerability scanner and identify at least 3 vulnerabilities or warnings it reports; for each, write a one-line description of what the risk is.

ANS : Based on a standard network and host vulnerability scan report (such as one generated from Nessus or OpenVAS targeting a lab environment or unpatched server), here are three common vulnerabilities and warnings typically flagged, along with their associated risks:

1. **Unsupported / End-of-Life (EOL) Operating System or Software**
    - **Risk:** The software or OS no longer receives security updates or vendor patches, leaving systems permanently vulnerable to newly discovered exploits.
2. **Weak or Default Administrative Credentials (e.g., Telnet/SSH/Web Console)**

- **Risk:** Attackers can easily bypass authentication using default factory passwords or dictionary brute-force attacks to gain full administrative control

3. **Outdated TLS Version / Weak Cryptographic Ciphers Enabled**
    - **Risk:** Allows adversaries to perform Man-in-the-Middle (MitM) attacks to intercept, decrypt, or tamper with sensitive data transmitted over the network.

Q.4 Pick any app you use daily (like Instagram, Zomato, or Paytm) and research one real vulnerability that was found in it in the past; write a short summary of what the vulnerability was and how it could have been detected by scanning tools.

ANS : A well-documented example of a security flaw in a major consumer platform is the **Blind SQL Injection (SQLi)** vulnerability identified in **Zomato's** web application infrastructure (publicly disclosed via bug bounty reports on HackerOne).

Vulnerability Summary: Blind SQL Injection in Backend Handlers

- **Target Application:** Zomato (www.zomato.com)
- **The Flaw:** Certain internal backend endpoints and widget handlers (such as parameters handling resource or order identifiers like order_id or res_id) failed to properly sanitize or parameterize user-supplied input before passing it into database queries.
- **The Risk:** Because it was a "blind" SQL injection vector, the application did not directly print database error messages or query outputs onto the page. Instead, an attacker could manipulate the logic of the backend database by injecting conditional statements or time-delay functions (e.g., forcing the database to sleep for a specified number of seconds). If the server response time or page behavior changed based on the injected condition, it proved that database queries were being manipulated, potentially allowing data extraction over time.

How Scanning Tools Could Have Detected It

Automated security tools can identify vulnerabilities of this nature through specific testing methodologies:

1. **Dynamic Application Security Testing (DAST) & Web Fuzzing:**

- Scanners like **OWASP ZAP** or **Burp Suite Professional** crawl the web application, discover input parameters (order_id, res_id), and automatically "fuzz" them by appending single quotes ('), mathematical conditions (1=1 vs 1=2), or SQL syntax symbols.

2. **Time-Based Heuristics:**
    - Advanced web scanners test for blind SQLi by injecting payload strings containing time-delay commands (such as WAITFOR DELAY or SLEEP()). If the scanner sends a request with a time-delay payload and notices that the server's HTTP response latency matches the requested delay (e.g., waiting an extra 5 seconds to reply), the tool flags the parameter as a high-severity time-based SQL injection vulnerability.
3. **Automated Exploitation Frameworks**
    - Once a potential injection point is flagged, tools like **SQLmap** can automate the process of confirming the vulnerability and mapping the database schema safely in a lab setting.

Q.5 Use ChatGPT or Copilot to generate a basic bash or PowerShell script that runs Nmap on a list of 3 IP addresses and saves the results to separate files; copy and run the script, and share the output files. Hint: Ask the AI tool for a script that loops through IPs and uses Nmap for each.

ANS : While I cannot directly execute local shell scripts or save files to your local disk from my cloud environment, I can provide the complete Bash script generated for this task. You can easily copy, save, and run this script in your Kali Linux or terminal environment to scan your chosen target IP addresses and automatically save the individual output files.

Bash Script: Automated Multi-Target Nmap Scanner

Save the following code into a file named nmap_batch_scanner.sh:

Bash

```
#!/bin/bash
```

ASSIGNMENT-9 : VULNERABILITY SCANNING

GUIDED BY : VIPUL MISTRI

```
# Define an array of 3 target IP addresses (e.g., localhost, scanme.nmap.org, and a gateway)
TARGETS=("127.0.0.1" "45.33.32.156" "192.168.1.1")

echo "=========================================="
echo "Starting Automated Nmap Batch Scan"
echo "=========================================="

for ip in "${TARGETS[@]}"; do
    # Create a clean filename by replacing dots with underscores
    filename="nmap_scan_${ip//./_}.txt"

    echo "[*] Scanning target: $ip"
    echo "[*] Results will be saved to: $filename"

    # Run Nmap with service detection (-sV) and normal output redirection (-oN)
    sudo nmap -sV -oN "$filename" "$ip"

    echo "[+] Finished scanning $ip"
    echo "------------------------------------------"
done

echo "All scans completed successfully!"
```

How to Run the Script

1. **Make the script executable:**

Bash

chmod +x nmap_batch_scanner.sh

2. **Execute the script with root privileges** (required for SYN stealth scans and certain OS/service probes):

Bash

sudo ./nmap_batch_scanner.sh

Expected Output Files Generated

Once the script finishes execution, it will generate three separate text files in your current working directory containing the full Nmap scan reports:

1. nmap_scan_127_0_0_1.txt
2. nmap_scan_45_33_32_156.txt
3. nmap_scan_192_168_1_1.txt